

15 Workflows Operationnels

Guide pratique — Plateforme Analyste SOC

Perimetre : ce document decrit 15 workflows concrets exploitant uniquement les outils deja integres et operationnels dans ta plateforme (30 pages UI + Sliver C2 + GoPhish + BloodHound + Ollama/Claude + RAG sur 11k docs + Credential Vault).

Organisation : 4 categories — SOC defensif (5), Red Team (5), Post-exploit (3), Reporting/Admin (2). Chaque workflow detaille objectif, outils utilises, etapes ordonnees, critere de succes et temps estime.

Usage : suivre en sequence OU piocher a la carte selon le contexte. Chaque etape est traduisible en action reelle dans la plateforme, pas un exercice theorique.

Genere le 2026-04-21 | Version plateforme V5 | 30 routes UI | 1046 endpoints API

Sommaire

#	Categorie	Workflow	Duree
1	SOC DEFENSIF	Triage rapide d'un incident critique avec AI + RAG	2 a 5 min
2	SOC DEFENSIF	Threat hunting — detection brute force multi-IP sur 24h	15 a 30 min
3	SOC DEFENSIF	Enrichissement IOC et propagation sur events historique...	10 a 20 min
4	SOC DEFENSIF	Generation et deploiement d'une regle Sigma par IA	20 a 40 min
5	SOC DEFENSIF	Execution d'un playbook SOAR sur incident majeur	5 a 10 min (machine) + review analy
6	RED TEAM	Reconnaissance OSINT complete d'une cible externe	30 a 90 min selon la taille du scope
7	RED TEAM	Pipeline pentest web auto — recon -> SQLi -> XSS -> rap...	1 a 3h
8	RED TEAM	Campagne phishing GoPhish scopee avec kill-switch	2 a 4h (campagne dure plusieurs jou
9	RED TEAM	Operations Sliver C2 — listener -> implant -> session -...	30 min a plusieurs jours
10	RED TEAM	Import BloodHound + analyse chemins d'attaque	1 a 2h selon taille du dump
11	POST-EXPLOIT	Credential harvesting + vault + reutilisation cross-ses...	45 min a 2h
12	POST-EXPLOIT	Brute force cible sur service decouvert en recon	30 min a plusieurs heures
13	POST-EXPLOIT	Cartographie reseau interne + lateral post-C2	1 a 3h
14	REPORTING	Rapport engagement final — MITRE coverage + exec summar...	1 a 2h de revue apres generation au
15	ADMIN	Audit securite interne de la plateforme (users, API key...	1 a 2h par trimestre

Workflow 01 — Triage rapide d'un incident critique avec AI + RAG

Objectif	Qualifier un incident critique (TP/FP/review) en < 3 minutes avec verdict IA + contexte historique RAG, puis passer à l'action.
Outils	/incidents, /ai/triage, /ai/rag, /soar/playbooks
Duree	2 à 5 min
Succes	Verdict pris, action déclenchée, incident transitionne et documente.

Etapes

1. Ouvrir /incidents et cliquer sur l'incident critique en haut de la liste.
2. Copier l'incident_id puis ouvrir /ai/triage, onglet 'By Incident ID', coller l'ID et lancer le triage (provider auto).
3. Vérifier le verdict (true_positive / false_positive / needs_review), la confiance, les techniques MITRE et les IOCs extraits.
4. Si confiance < 70 %, ouvrir /ai/rag et rechercher les éléments clés de l'incident (IP source, username, event_type) sur 168h de corpus.
5. Décider : si TP -> /soar/playbooks pour déclencher le playbook de confinement ; si FP -> fermer avec le tag 'false_positive' ; si review -> assigner.
6. Documenter la décision dans la timeline de l'incident (note + evidences MITRE/IOCs).

Workflow 02 — Threat hunting — detection brute force multi-IP sur 24h

Objectif	Identifier les campagnes de brute force distribuée (low-and-slow) qui échappent aux seuils classiques.
Outils	/search (CQL), /hunting, /ioc
Duree	15 à 30 min
Succes	Liste d'IPs malveillantes enrichies en IOCs réutilisables + query sauvegardée pour répétition.

Etapes

1. Ouvrir /search et charger la query prédéfinie 'Brute Force Detection' depuis la library.
2. Adapter la fenêtre (-24h latest=now) et ajuster le seuil (where count > 10 -> > 5 pour low-and-slow).
3. Exporter les src_ip résultats (bouton Export CSV).
4. Pivoter chaque IP suspecte dans /threat-intel (AbuseIPDB + OTX) pour score reputation.

5. Créer un IOC dans /ioc pour chaque IP confirmée malveillante (TTL 30j, confiance 80, tags : 'brute-force', 'auth').
6. Sauvegarder la query modifiée en 'saved query' pour exécution hebdo (schedule: 0 6 * * 1).

Workflow 03 — Enrichissement IOC et propagation sur events historiques

Objectif	A partir d'un nouvel IOC (IP/domain/hash), retro-chercher les events historiques qui l'ont touche sans etre detectes.
Outils	/ioc, /search, /incidents
Duree	10 a 20 min
Succes	Chaque host touche par l'IOC est identifie avec sa chronologie.

Etapas

1. Ajouter le nouvel IOC dans /ioc (type, value, source, confiance, TTL).
2. Le systeme enrichit auto via threat intel (VirusTotal/OTX si configures).
3. Ouvrir /search et lancer une CQL : 'src_ip="" OR dst_ip="" | stats count by host, event_type | sort -count'.
4. Pour chaque host touche, ouvrir le timeline detaille (! timechart count by event_type).
5. Si correlation suspecte, creer un incident manuel depuis /incidents avec lien vers l'IOC et la query.
6. Exporter le resultat en JSON pour investigation forensic externe.

Workflow 04 — Generation et deployment d'une regle Sigma par IA

Objectif	Passer d'un incident recent a une regle de detection deployable, sans ecrire de Sigma a la main.
Outils	/ai/rule-gen, /ai/triage, /search
Duree	20 a 40 min
Succes	Nouvelle regle deployee, testee, monitoree. Detection coverage MITRE augmentee.

Etapas

1. Selectionner un incident TP recent (ex: lateral movement via psexec).
2. Ouvrir /ai/rule-gen et fournir : description courte + extrait de log + MITRE technique (T1021.002).
3. L'IA genere une regle Sigma avec detection, condition, level, tags.
4. Tester la regle contre le corpus : copier le pattern en CQL dans /search et verifier qu'elle match l'event source ET qu'elle ne sature pas en FP.

5. Si OK : valider et deployer (le backend convertit Sigma -> regle de correlation active).
6. Monitorer les 48h suivantes via /alerts pour confirmer les matches.

Workflow 05 — Execution d'un playbook SOAR sur incident majeur

Objectif	Automatiser la reponse sur un incident (confinement, enrichissement, notification) via un playbook pre-defini.
Outils	/soar/playbooks, /soar/executions, /incidents, /alerts
Duree	5 a 10 min (machine) + review analyste
Succes	Host isole, evidences collectees, equipe notifiee, timeline incident mise a jour.

Etapas

1. Depuis /incidents, ouvrir un incident de type 'malware.detect' ou 'ransomware'.
2. Ouvrir /soar/playbooks, choisir le playbook 'Malware Containment' (ou equivalent).
3. Fournir les inputs (incident_id, host, user). Le playbook execute : isolation host, kill process, snapshot, notif Slack.
4. Suivre l'execution en live dans /soar/executions (status par etape).
5. Verifier les resultats : channel Slack dans /alerts, audit log, evidences attachees a l'incident.
6. Si l'une des etapes echoue, cliquer 'Retry step' ou passer en manuel.

Workflow 06 — Reconnaissance OSINT complete d'une cible externe

Objectif	Construire un profil attaquant d'une cible (domaine client engagement) en une passe automatisée.
Outils	/recon, /pentest/subdomain, /pentest/crawler, /pentest/netscan
Duree	30 a 90 min selon la taille du scope
Succes	Surface d'attaque complete cartographiee, prete a etre passee en phase exploitation.

Etapas

1. Ouvrir /recon et lancer un scan multi-modules sur le domaine (subdomain + certs + tech_stack + emails).
2. Pendant que /recon tourne, ouvrir /pentest/subdomain en parallele pour une passe DNS + CT logs + wordlist plus profonde.
3. A la fin, exporter les subdomains actifs en liste.
4. Pour chaque subdomain web, lancer /pentest/crawler (profondeur 2, formulaires + endpoints caches).
5. Pour les subdomains avec services exposes, lancer /pentest/netscan (fingerprint services + versions).
6. Consolider : une liste finale URLs / services / versions / emails a partir des 4 modules.

Workflow 07 — Pipeline pentest web auto — recon -> SQLi -> XSS -> rapport

Objectif	Exploiter un site web avec la chaine auto sans intervention manuelle entre les etapes.
Outils	/pentest/pipeline, /pentest/sqli, /pentest/xss-engine, /reports
Duree	1 a 3h
Succes	Rapport pentest web complet en PDF, vulnerabilites classees CVSS + OWASP.

Etapas

1. Ouvrir /pentest/pipeline et creer un pipeline 'Web Quick Assess'.
2. Etapes : crawler (profondeur 2) -> sqli (5 techniques, auto-detect DBMS) -> xss-engine (6 contexts) -> report.
3. Cibler l'URL, valider le scope (doit matcher un engagement actif avec kill-switch inactif).
4. Lancer. Monitorer la progression (chaque etape produit des findings stockees en DB).

5. Si SQLi hit : ouvrir /pentest/sqli pour raffiner (tamper, extraction donnees).
6. Si XSS hit : ouvrir /pentest/xss-engine pour generer payload contextuel final.
7. Generer le rapport final dans /reports (template pentest technique, avec preuves et recommandations).

Workflow 08 — Campagne phishing GoPhish scopee avec kill-switch

Objectif	Lancer une campagne phishing controlee, avec enforcement strict du scope RoE et observation temps reel.
Outils	/redteam/phishing, GoPhish (:3333), /alerts
Duree	2 a 4h (campagne dure plusieurs jours)
Succes	Campagne executee dans le scope, metriques collectees, rapport de conformite RoE disponible.

Etapes

1. Depuis /redteam/phishing, verifier que l'engagement cible est actif et que le kill-switch est off.
2. Creer une campagne : template email + landing page + liste cibles (CSV importe).
3. Scope check : le backend verifie que TOUS les domaines cibles matchent le scope RoE de l'engagement, sinon refus.
4. Envoi : le backend push vers GoPhish via API, puis sync engine regulier met a jour les compteurs (sent/opened/clicked/submitted).
5. Monitorer en live le taux de clic et les credentials submits.
6. Si incident (plainte client, hors scope) : activer le kill-switch engagement -> stop auto de la campagne GoPhish, audit trail ecrit.

Workflow 09 — Operations Sliver C2 — listener -> implant -> session -> pivot

Objectif	Etablir une session C2 operationnelle et pivoter vers les machines voisines via BloodHound.
Outils	/pentest/c2, /redteam/console, /redteam/bloodhound
Duree	30 min a plusieurs jours
Succes	Session Sliver active + pivot BloodHound affichant au moins un chemin vers un high-value asset.

Etapes

1. Verifier que Sliver daemon tourne (localhost:31337) et est configure dans .env.
2. Ouvrir /pentest/c2, onglet 'Listeners' : creer un listener HTTPS sur le port cible (ex: :8443).

3. Onglet 'Implants' : generer un implant Python/PowerShell avec callback URL + beacon interval + obfuscation.
4. Deployer l'implant sur la cible (phishing payload, recup credentials, etc.).
5. Attendre la session dans /redteam/console (event 'session.new' via WS).
6. Ouvrir le terminal live, executer 'whoami /priv', 'ipconfig /all', 'net user /domain'.
7. Si dataset BloodHound importe : ouvrir le pivot read-only a droite pour voir les chemins d'attaque depuis cette session (local admins, high-value targets).

Workflow 10 — Import BloodHound + analyse chemins d'attaque

Objectif	Exploiter un dump AD (SharpHound/AzureHound) pour identifier les quick-wins de privesc/lateral.
Outils	/redteam/bloodhound, /redteam/console
Duree	1 a 2h selon taille du dump
Succes	Liste priorisee de chemins d'attaque valides + notes copiees dans le rapport d'engagement.

Etapas

1. Recuperer le dump SharpHound (zip avec json users/groups/computers/sessions).
2. Ouvrir /redteam/bloodhound et creer un nouveau dataset associe a l'engagement.
3. Upload du zip. Le backend parse et stocke les noeuds/reactions (peut prendre quelques minutes).
4. Dataset chargee : ouvrir la vue graph, naviguer entre users/computers/groups.
5. Lancer des queries pre-built : 'Shortest path to Domain Admins', 'Users with DCSync rights', 'Kerberoastable users'.
6. Pour chaque chemin critique, copier les edges en notes (bouton 'COPY AS NOTE' dans le pivot).
7. Si une session Sliver correspond a un noeud du dataset, le pivot de /redteam/console montre auto les paths depuis cette session.

Workflow 11 — Credential harvesting + vault + reutilisation cross-session

Objectif	Extraire credentials browser/cloud/secrets depuis une session compromise, les stocker chiffrés (Fernet), les reutiliser.
Outils	/redteam/console + modules backend /post-exploit/*
Duree	45 min a 2h
Succes	Credentials extraits + chiffrés + reutilisés avec succès pour un pivot lateral.

Etapas

1. Depuis une session Sliver active, exécuter les modules post-exploit : browser (Chrome, Firefox, Edge), cloud (AWS/Azure CLI files), secrets (env vars, config files).
2. Les creds extraits sont pushés auto dans le Credential Vault (chiffrement Fernet, audit log).
3. Consulter le vault via l'API (/post-exploit/vault/list) : type, source_host, value (dechiffrée à l'affichage seulement).
4. Utiliser une cred extraite pour une 2e session : passer l'username/password à /pentest/brute sur un service voisin (SSH/RDP/SMB).
5. Si match : nouvelle session Sliver demandée sur ce host, pivot lateral complet.
6. Tout l'usage est audité (qui utilise quelle cred, sur quelle cible).

Workflow 12 — Brute force cible sur service decouvert en recon

Objectif	Cracker un service exposé (SSH/HTTP login/FTP) avec wordlist + rules après l'avoir trouvé en recon.
Outils	/pentest/netscan, /pentest/brute
Duree	30 min a plusieurs heures
Succes	Cred obtenue sur le service ou abandonnée proprement dans le scope.

Etapas

1. Après /pentest/netscan, repérer un service login exposé (ex: SSH :22 sur un subdomain).
2. Ouvrir /pentest/brute, choisir le protocole, renseigner host:port.
3. Fournir la liste des usernames (depuis /recon emails) et la wordlist password (rockyou.txt, ou générée par wordgen).
4. Configurer : délai entre tentatives (anti-lockout), max parallel connexions, kill-switch sur trigger (ex: 50 fails consécutifs).
5. Lancer le brute force. Monitorer les findings en temps réel.

6. Si hit : cred ajoute auto au Credential Vault, incident cree cote SOC (boucle bleue/rouge deliberee sur la plateforme).

Workflow 13 — Cartographie reseau interne + lateral post-C2

Objectif	Une fois C2 etabli, cartographier le reseau interne et identifier les prochaines cibles laterales.
Outils	/redteam/console, /pentest/netscan, /redteam/bloodhound
Duree	1 a 3h
Succes	Carte reseau interne + 3 targets prioritaires valides + plan lateral.

Etapes

1. Depuis la session Sliver active, executer 'arp -a', 'route print', 'netstat -rn' pour lister voisins et gateway.
2. Upload ces donnees dans /pentest/netscan pour structuration (network map).
3. Lancer un ping sweep + port scan sur le /24 local depuis la session (via Sliver execute, pas depuis l'attaquant directement).
4. Correler avec le dataset BloodHound : croiser les IPs decouvertes avec les ordinateurs AD et leurs relations.
5. Identifier 3-5 targets prioritaires (high value, admin paths, shortest).
6. Pour chaque target, preparer un playbook lateral (pass-the-hash, overpass, kerberoast selon le contexte).

Workflow 14 — Rapport engagement final — MITRE coverage + exec summary

Objectif	Produire le rapport livrable client avec mapping MITRE automatique et resume executif.
Outils	/reports, /redteam/bloodhound, /pentest/c2, /redteam/phishing
Duree	1 a 2h de revue apres generation auto
Succes	PDF livrable conforme (exec + technique + MITRE + annexes), pret a etre remis.

Etapes

1. Verifier que l'engagement est 'closed' et que toutes les findings/sessions/campagnes sont rattachees.
2. Ouvrir /reports, choisir le template 'Engagement Final' (executive + technique).
3. Le backend agrege : findings web, sessions C2, credentials, campagnes phishing, chemins BloodHound.
4. Revue du draft : verifier l'exec summary genere par l'IA, ajuster les paragraphes sensibles.
5. MITRE coverage : le rapport contient auto un MITRE Navigator export des techniques reellement utilisees.
6. Export PDF + remise client (via canal securise, hors plateforme).
7. Archiver l'engagement : audit trail signe + snapshot DB pour tracabilite 7 ans.

Workflow 15 — Audit securite interne de la plateforme (users, API keys, 2FA)

Objectif	Verifier que la plateforme elle-meme respecte les bonnes pratiques (hygiene comptes + acces).
Outils	/admin, /profile, audit logs
Duree	1 a 2h par trimestre
Succes	Comptes propres, cles rotatees, rapport d'audit interne archive pour conformite.

Etapas

1. Ouvrir /admin et lister tous les users (filter par role : admin, analyst, read-only).
2. Verifier : chaque admin a 2FA active ; pas de compte dormant > 90j ; mots de passe changes recemment.
3. Ouvrir /admin -> API keys : lister les cles, verifier last_used, rotation > 180j, scope minimal.
4. Revoquer les cles non utilisees depuis 90j+.
5. Verifier /admin -> audit logs : actions sensibles (user creation, role change, key gen) tracees.
6. Tester le recovery flow sur un compte test (forgot password + 2FA recovery code).
7. Documenter le tout dans un rapport d'audit interne (template /reports existe).

En resume

Ces 15 workflows couvrent le cycle complet que ta plateforme supporte aujourd'hui, du triage defensif au reporting post-engagement. Chacun est executable **immédiatement**, sans module manquant ni dependance externe non configuree.

Prochaines etapes suggerees :

- Executer 1 workflow par categorie cette semaine pour valider end-to-end.
- Mesurer les temps reels vs estimations et ajuster.
- Documenter les deltas dans /pentest/docs (sections internes).
- Pour les workflows 4, 7, 14 : capturer un screencast de demonstration.
- Si une etape echoue, ouvrir un ticket avec l'endpoint + payload + reponse.

Document genere automatiquement par scripts/gen_workflows_pdf.py — regenerer a chaque ajout de module important.